

WHITE PAPER · STAND OKTOBER 2026

NIS2 und ISO 27001 **pragmatisch** umsetzen

Ein geführter Weg für Mittelstand und öffentliche Stellen – vom „Sind wir betroffen?“ bis zum prüffähigen Nachweis.

NACH DER LEKTÜRE WISSEN SIE

- ✓ was das NIS2-Umsetzungsgesetz seit dem 6. Dezember 2025 konkret von Ihnen verlangt,
- ✓ wo ein bestehendes ISO-27001-Managementsystem trägt – und wo nicht,
- ✓ wie Sie in fünf Schritten zu einem belastbaren Umsetzungsstand kommen.

Dr. Sait Yalazay

CISO · Lead Auditor ISO/IEC 27001 und 42001 · CISM
über 20 Jahre Informationssicherheit und Compliance

uniq.cyberwerk.online

Kein Rechtsrat – siehe Hinweis auf Seite 14

Auf einen Blick

NIS2 ist in Deutschland kein Zukunftsthema mehr. Das Umsetzungsgesetz gilt seit Dezember 2025 – ohne allgemeine Übergangsfrist. Gleichzeitig laufen die Fristen von EU AI Act und Cyber Resilience Act an. Wer jetzt strukturiert vorgeht, kommt mit überschaubarem Aufwand zu einem Stand, den Geschäftsleitung, Aufsicht und Prüfer nachvollziehen können.

1

Die Pflichten gelten bereits

Das NIS2UmsuCG ist am 6.12.2025 in Kraft getreten. Statt bisher rund 4.500 KRITIS-Betreibern fallen nach Schätzungen rund 29.500 Einrichtungen unter das neue BSI-Gesetz. Die Registrierungsfrist ist abgelaufen.

2

Die Geschäftsleitung ist persönlich gefordert

Sie muss die Risikomanagementmaßnahmen umsetzen, ihre Umsetzung überwachen und regelmäßig an Schulungen teilnehmen. Delegieren lässt sich die Arbeit, nicht die Verantwortung.

3

Zehn Maßnahmen, drei Meldefristen

Das Gesetz verlangt zehn Mindestmaßnahmen (§ 30 BSIG, Art. 21 NIS2) und ein Meldewesen mit 24 Stunden, 72 Stunden und einem Monat. Bußgelder reichen bis 10 Mio. € oder 2 % des weltweiten Umsatzes.

4

ISO 27001 ist das Rückgrat – nicht der Haken

Ein gelebtes ISMS deckt einen großen Teil ab. Meldewesen, Registrierung, Schulung der Leitung und die Tiefe der Lieferkettenprüfung müssen trotzdem gezielt nachgezogen werden.

5

Der Engpass ist selten Wissen, sondern Überblick

Die meisten Organisationen kennen ihre Lücken in Teilen. Was fehlt, ist eine einzige, aktuelle Sicht: Welche Anforderung gilt, wie ist der Stand, wer macht was bis wann, und was lässt sich belegen? Dieses White Paper beschreibt einen geführten Weg dorthin – unabhängig vom Werkzeug. Wie UniqSuite ihn unterstützt, zeigen die Seiten 11 bis 13.

Die Lage im Herbst 2026

Am 5. Dezember 2025 wurde das „Gesetz zur Umsetzung der NIS-2-Richtlinie und zur Regelung wesentlicher Grundzüge des Informationssicherheitsmanagements in der Bundesverwaltung“ (NIS2UmsuCG) verkündet (BGBl. 2025 I Nr. 301). Es hat das BSI-Gesetz neu gefasst und ist am Folgetag in Kraft getreten. Eine allgemeine Übergangsfrist für die Sicherheitsmaßnahmen sieht es nicht vor.

Damit verschiebt sich die Frage von „Kommt das?“ zu „Wie weit sind wir?“. Parallel greifen weitere europäische Regelwerke, die viele Einrichtungen zusätzlich betreffen:

-
- A vertical timeline with a central grey line and circular markers. The markers are filled for events in 2025 and 2026, and empty for events in 2027 and 2028.
- 6. Dez. 2025** ● **NIS2UmsuCG in Kraft.** Neues BSIG mit Pflichten für besonders wichtige und wichtige Einrichtungen.
 - März 2026** ● **Registrierungsfrist abgelaufen** (drei Monate nach Inkrafttreten, § 33 BSIG). Nachzügler sollten sich unverzüglich im BSI-Portal registrieren.
 - 2. Aug. 2026** ● **EU AI Act:** Transparenzpflichten nach Art. 50 gelten. Verbote und KI-Kompetenz gelten bereits seit Februar 2025.
 - 11. Sep. 2026** ● **Cyber Resilience Act:** Meldepflichten der Hersteller für aktiv ausgenutzte Schwachstellen und schwere Vorfälle (Art. 14) gelten.
 - 2. Dez. 2027** ○ **EU AI Act:** Pflichten für Hochrisiko-KI nach Anhang III – verschoben durch die Verordnung (EU) 2026/1744.
 - 11. Dez. 2027** ○ **Cyber Resilience Act** gilt vollständig.
 - 2. Aug. 2028** ○ **EU AI Act:** Hochrisiko-KI in Produkten nach Anhang I.

Warum es drängt. Bitkom beziffert den Schaden durch Datendiebstahl, Spionage und Sabotage in Deutschland für 2026 auf mindestens 211 Mrd. €. Rund drei Viertel davon gehen auf Cyberangriffe zurück; 96 % der befragten Unternehmen waren betroffen oder vermutlich betroffen.

Bitkom, Wirtschaftsschutz 2026, n = 1.003

Achtung bei alten Unterlagen. Viele Leitfäden nennen noch den 17. Oktober 2024 als Starttermin für Deutschland, den 2. August 2026 für Hochrisiko-KI oder Bußgelder nur in einer Stufe. Das ist überholt. Prüfen Sie das Datum jeder Quelle.

Bin ich betroffen?

Ob eine Einrichtung unter das BSIG fällt, hängt in der Regel von zwei Fragen ab: Ist sie in einem der erfassten Sektoren tätig, und erreicht sie die Größenschwelle? Für einige Dienste gilt das Gesetz unabhängig von der Größe. Die folgende Übersicht ist bewusst vereinfacht.

1 · Erbringen Sie Leistungen in einem erfassten Sektor?

Sektoren hoher Kritikalität

Energie, Transport und Verkehr, Finanzwesen und Versicherungen, Gesundheit, Trinkwasser, Abwasser, digitale Infrastruktur, IKT-Dienstleistungsmanagement, Weltraum, öffentliche Verwaltung des Bundes

Sonstige kritische Sektoren

Post- und Kurierdienste, Abfallbewirtschaftung, Chemie, Lebensmittel, verarbeitendes Gewerbe (u. a. Medizinprodukte, Elektronik, Maschinen, Fahrzeuge), digitale Dienste, Forschung



2 · Welche Größe hat Ihre Einrichtung? (Konzernzahlen können zählen)

Großes Unternehmen

ab 250 Beschäftigten oder mehr
als 50 Mio. € Umsatz und mehr
als 43 Mio. € Bilanzsumme

hohe Kritikalität → besonders wichtig

sonstige → wichtig

Mittleres Unternehmen

ab 50 Beschäftigten oder mehr
als 10 Mio. € Umsatz und mehr
als 10 Mio. € Bilanzsumme

beide Sektorgruppen → wichtig

Kleiner

In der Regel nicht erfasst – **außer** bei Diensten, die größenunabhängig gelten, z. B. qualifizierte Vertrauensdienste, TLD-Registries, DNS-Dienste oder öffentliche Telekommunikation.

Öffentliche Stellen. Das BSIG erfasst die Bundesverwaltung. Für Landes- und Kommunalverwaltungen gelten die Regelungen der Länder. Kommunale Unternehmen wie Stadtwerke, Krankenhäuser oder Entsorger können dagegen unmittelbar unter das BSIG fallen.

Mittelbar betroffen. Auch wer selbst nicht erfasst ist, spürt NIS2 über seine Kunden: Erfasste Einrichtungen müssen die Sicherheit ihrer Lieferkette prüfen und geben Anforderungen vertraglich weiter.

Verbindlich klärt die Betroffenheit erst die Prüfung im Einzelfall. Eine gute Hilfe ist die Betroffenheitsprüfung des BSI (bsi.bund.de). Dokumentieren Sie das Ergebnis datiert und mit Begründung – auch wenn es „nicht betroffen“ lautet.

Zehn Mindestmaßnahmen – und wo die Lücken typischerweise liegen

§ 30 BSIG übernimmt die zehn Maßnahmen aus Art. 21 Abs. 2 der NIS2-Richtlinie. Sie müssen geeignet, verhältnismäßig und wirksam sein und einem gefahrenübergreifenden Ansatz folgen. Die Tabelle zeigt für jede Maßnahme den passenden Bezug in ISO/IEC 27001:2022, die Lücke, die in der Praxis am häufigsten bleibt, und den Nachweis, nach dem gefragt wird.

Maßnahme	ISO 27001:2022	Typische Lücke	Nachweis
a · Risikoanalyse und Sicherheitskonzepte	Kap. 6.1.2, 6.1.3, 8.2; A.5.1	Risikoanalyse ohne Lieferkette und ohne gefahrenübergreifende Sicht	Freigegebene Leitlinie, aktueller Risikobericht
b · Bewältigung von Sicherheitsvorfällen	A.5.24–A.5.28, A.6.8	Kein festgelegtes Kriterium für „erheblich“, kein geübter Meldeweg zum BSI	Vorfallregister, Meldevorlagen, Übungsprotokoll
c · Betriebskontinuität, Backup, Krisenmanagement	A.5.29, A.5.30, A.8.13, A.8.14	Wiederherstellung nie getestet, Krisenstab nur auf Papier	Notfallpläne, Restore-Testprotokolle
d · Sicherheit der Lieferkette	A.5.19–A.5.23	Lieferanten erfasst, aber nicht nach Kritikalität bewertet	Lieferantenbewertungen, Vertragsklauseln
e · Sicherheit bei Erwerb, Entwicklung und Wartung, inkl. Schwachstellen	A.5.20, A.8.8, A.8.25–A.8.29	Patches ohne Fristen, kein Verfahren zur Offenlegung von Schwachstellen	Schwachstellen- und Patchberichte

Für digitale Dienste konkreter. Für bestimmte Anbieter – etwa DNS-Dienste, TLD-Registries, Cloud- und Rechenzentrumsdienste, Content-Delivery-Netze, Managed (Security) Services, Online-Marktplätze, Suchmaschinen, soziale Netzwerke und Vertrauensdienste – legt die Durchführungsverordnung (EU) 2024/2690 die technischen und methodischen Anforderungen im Detail fest. Wer dazu gehört, sollte seine Gap-Analyse an dieser Verordnung ausrichten.

Fortsetzung auf der nächsten Seite. Die Zuordnung zu ISO 27001 ist eine fachliche Orientierung des Autors, keine amtliche Konkordanz.

Maßnahme	ISO 27001:2022	Typische Lücke	Nachweis
f · Bewertung der Wirksamkeit	Kap. 9.1, 9.2; A.5.35	Audits ja, Kennzahlen zur Wirksamkeit nein	Kennzahlen, Auditberichte, Managementbewertung
g · Cyberhygiene und Schulungen	Kap. 7.2, 7.3; A.6.3	Schulung der Beschäftigten ja, der Geschäftsleitung nein	Schulungsnachweise inkl. Leitung
h · Kryptografie und Verschlüsselung	A.8.24	Verschlüsselung im Einsatz, aber kein Konzept und keine Schlüsselverwaltung	Kryptokonzept
i · Personal, Zugriffskontrolle, Asset-Management	A.5.9–A.5.18, A.6.1–A.6.5	Inventar unvollständig, Berechtigungen nie rezertifiziert	Inventar, Rezertifizierungsprotokolle
j · MFA, gesicherte Kommunikation, Notfallkommunikation	A.5.14, A.8.5	MFA nur für Fernzugriff, kein Notfall-Kommunikationsweg	MFA-Abdeckung, Notfallkommunikationsplan

Meldepflicht bei erheblichen Sicherheitsvorfällen (§ 32 BSIG, Art. 23 NIS2)

24 h Frühe Erstmeldung ab Kenntnis	72 h Meldung mit erster Bewertung	auf Ersuchen Zwischenmeldung	1 Monat Abschlussmeldung nach der Meldung
--	---	--	---

Dauert der Vorfall länger, tritt an die Stelle der Abschlussmeldung zunächst eine Fortschrittmeldung. Entscheidend ist ein vorab festgelegtes Kriterium, wann ein Vorfall „erheblich“ ist – sonst beginnt die Diskussion, während die Uhr läuft.

Bußgeldrahmen (§ 65 BSIG, Art. 34 NIS2)

Einrichtung	Höchstbetrag – der höhere Wert gilt
besonders wichtig	10 Mio. € oder 2 % des weltweiten Jahresumsatzes
wichtig	7 Mio. € oder 1,4 % des weltweiten Jahresumsatzes

Registrierung (§ 33 BSIG)

Erfasste Einrichtungen müssen sich beim BSI registrieren und Änderungen ihrer Angaben mitteilen. Die gesetzliche Frist von drei Monaten nach Inkrafttreten ist abgelaufen. Wer noch nicht registriert ist, holt das unverzüglich nach – und hält fest, wer die Angaben künftig aktuell hält.

Die Geschäftsleitung in der Pflicht

§ 38 BSIG setzt Art. 20 der Richtlinie um und richtet sich an die Leitung selbst: Sie muss die Risikomanagementmaßnahmen umsetzen, ihre Umsetzung überwachen und regelmäßig an Schulungen teilnehmen. Verletzt sie diese Pflichten schuldhaft, haftet sie ihrer Einrichtung nach den gesellschaftsrechtlichen Regeln.

Umsetzen

Leitlinie, Risikobehandlung und Maßnahmenplan werden förmlich freigegeben und umgesetzt – nachvollziehbar und datiert.

Überwachen

Der Umsetzungsstand kommt regelmäßig auf den Tisch:
Was ist erledigt, was ist überfällig, wo liegen Risiken?

Schulen

Die Leitung erwirbt selbst genug Wissen, um Risiken zu erkennen und Maßnahmen zu bewerten.

Sieben Fragen, die eine Geschäftsleitung beantworten können sollte

1. Sind wir besonders wichtige oder wichtige Einrichtung – und ist das schriftlich begründet?
2. Sind wir beim BSI registriert, und wer hält die Angaben aktuell?
3. Welche Anforderungen sind offen, und welche davon sind Pflicht?
4. Wer meldet einen erheblichen Vorfall innerhalb von 24 Stunden – auch am Wochenende?
5. Welche Lieferanten sind für uns kritisch, und wann wurden sie zuletzt bewertet?
6. Wann haben wir zuletzt eine Wiederherstellung aus dem Backup erfolgreich getestet?
7. Wann hat die Leitung selbst zuletzt an einer Schulung teilgenommen?

Praxistipp: Eine Seite reicht. Ein monatlicher Ein-Seiten-Bericht mit Gesamtstand, überfälligen Maßnahmen und offenen Pflichtanforderungen erfüllt die Überwachungspflicht besser als ein jährlicher Foliensatz – und lässt sich als Nachweis ablegen.

ISO 27001 als Rückgrat – und was fehlt

Wer ein ISMS nach ISO/IEC 27001 betreibt, hat das wichtigste Fundament: Geltungsbereich, Risikomethode, Rollen, Dokumentenlenkung, interne Audits und Managementbewertung. NIS2 baut auf genau diesen Mechanismen auf. Pauschale Prozentangaben, wie viel ein Zertifikat „abdeckt“, sind trotzdem irreführend – entscheidend ist, ob die Maßnahmen im Geltungsbereich wirksam umgesetzt sind.

Was ein gelebtes ISMS mitbringt

- ✓ Methode für Risikoanalyse und -behandlung
- ✓ Erklärung zur Anwendbarkeit (SoA)
- ✓ Rollen, Verantwortlichkeiten, Dokumentenlenkung
- ✓ Interne Audits, Korrekturmaßnahmen, Managementbewertung
- ✓ Großteil der technischen und organisatorischen Kontrollen aus Anhang A

Was gezielt nachzuziehen ist

- **Geltungsbereich:** Er muss die erfassten Dienste vollständig umfassen – nicht nur einen zertifizierten Ausschnitt.
- **Meldewesen:** Erheblichkeitskriterien, 24/72-Stunden-Prozess, Meldestelle.
- **Registrierung** beim BSI und Pflege der Angaben.
- **Leitung:** Umsetzung, Überwachung und Schulung als nachweisbare Pflichten.
- **Lieferkette:** Bewertung der Sicherheitspraktiken direkter Lieferanten, inklusive Entwicklungsverfahren.
- **Notfallkommunikation** und gesicherte Kommunikation.

Einmal bewerten, mehrfach nutzen

Viele Anforderungen aus NIS2, ISO 27001, ISO 42001, dem AI Act und dem CRA meinen inhaltlich dasselbe – etwa Zugriffskontrolle, Vorfallsbehandlung oder Lieferantenbewertung. Wer sie getrennt pflegt, bewertet dieselbe Frage mehrfach und riskiert widersprüchliche Antworten. Besser ist ein gemeinsamer Kontrollpunkt, dessen Bewertung in jedem betroffenen Regelwerk gilt. Gilt eine Antwort für mehrere Regelwerke, zählt im Zweifel die schwächste Umsetzung.

Der geführte Weg in fünf Schritten

Der Weg folgt dem Plan-Do-Check-Act-Zyklus, den ISO 27001 und die Aufsicht erwarten. Er ist werkzeugunabhängig – entscheidend ist, dass jeder Schritt ein Ergebnis erzeugt, das der nächste nutzt.

1

Scope klären

Betroffenheit, Einrichtung, Dienstleistungen, Standorte und Verantwortliche festhalten. Registrierung prüfen.

2

Gap-Analyse

Jede Anforderung einmal bewerten: umgesetzt, teilweise, nicht umgesetzt oder begründet nicht anwendbar.

3

Risiken priorisieren

Lücken mit Risiken verknüpfen. Pflichtenforderungen und hohe Risiken zuerst.

4

Planen und umsetzen

Erklärung zur Anwendbarkeit, Maßnahmen mit Zuständigen und Fristen, Status laufend pflegen.

5

Prüfen und berichten

Wirksamkeit messen, intern auditieren, an die Leitung berichten, Korrekturen nachverfolgen.

Beispiel: Nordwerk Energie GmbH

Fiktives Unternehmen, Demo-Daten aus UniqSuite

Ein regionaler Energieversorger mit rund 400 Beschäftigten ist als besonders wichtige Einrichtung erfasst und strebt zusätzlich die ISO-27001-Zertifizierung an. Für einige Prozesse setzt er KI-Anwendungen ein und nimmt deshalb den AI Act und ISO 42001 mit auf.

Nach der Gap-Analyse ergibt sich ein Gesamtstand von 59 %. Die Leitung sieht auf einer Seite, was Aufmerksamkeit braucht: zwei überfällige Maßnahmen, eine fällige Meldung und offene Pflichtenforderungen je Regelwerk. Daraus entsteht ein Maßnahmenplan mit Zuständigen und Fristen, dessen Fortschritt automatisch in den Gesamtstand zurückfließt.

Regelwerk	Anforderungen	Stand
NIS2	268 · 241 anwendbar	60 %
ISO/IEC 27001	318 · 315 anwendbar	62 %
ISO/IEC 42001	111 · 107 anwendbar	60 %
EU AI Act	130 · 108 anwendbar	46 %

Gewichteter Umsetzungsstand je Regelwerk im Demo-Mandanten

Reifegrad statt Ja/Nein. Im ersten Durchgang genügt die Dreiteilung umgesetzt – teilweise – nicht umgesetzt. In der Vertiefung lohnt eine Reifegradskala mit Nachweisen je Anforderung: Sie macht Fortschritt sichtbar, bevor eine Lücke ganz geschlossen ist.

Sechs typische Fehler

- ✗ Die Betroffenheit nur mündlich klären**
Ohne datierte, begründete Prüfung fehlt der erste Nachweis.
- ✗ Das Meldewesen erst im Ernstfall klären**
Wer erst nach dem Vorfall definiert, was erheblich ist, verliert die 24 Stunden.
- ✗ „Nicht anwendbar“ ohne Begründung**
Jeder Ausschluss braucht eine nachvollziehbare Begründung in der SoA.
- ✗ Den ISMS-Scope ungeprüft übernehmen**
Der zertifizierte Bereich deckt oft nicht alle erfassten Dienste ab.
- ✗ Jedes Regelwerk in einer eigenen Tabelle**
Doppelte Arbeit und widersprüchliche Antworten zur gleichen Frage.
- ✗ Die Leitung nur informieren**
Umsetzung, Überwachung und Schulung müssen belegbar sein.

Häufige Fragen

Gibt es ein „NIS2-Zertifikat“?

Nein. Das Gesetz kennt keine allgemeine Zertifizierung. Eine ISO-27001-Zertifizierung ist ein starkes Indiz für ein funktionierendes ISMS, ersetzt aber nicht den Nachweis der gesetzlichen Pflichten.

Wir sind ISO-27001-zertifiziert. Sind wir fertig?

Nicht automatisch. Prüfen Sie Geltungsbereich, Meldewesen, Registrierung, Pflichten der Leitung und Lieferkette (Seite 8).

Wie lange dauert eine Gap-Analyse?

Das hängt von Größe und Vorarbeit ab. Ein erster vollständiger Durchgang ist bei guter Vorbereitung in wenigen Arbeitstagen machbar; die Vertiefung mit Nachweisen dauert länger.

Wir sind eine Kommune. Gilt das BSIG für uns?

Für die Kommunalverwaltung gelten die Regelungen Ihres Landes. Kommunale Unternehmen können dagegen unmittelbar unter das BSIG fallen.

Müssen wir alle Anforderungen sofort erfüllen?

Die Pflichten gelten seit Dezember 2025. Wer noch Lücken hat, braucht einen priorisierten, von der Leitung freigegebenen Plan – und muss ihn sichtbar abarbeiten.

Was gilt, wenn wir auch KI einsetzen?

Der AI Act gilt unabhängig von NIS2. KI-Kompetenz und Verbote gelten bereits; ein KI-Register ist der erste sinnvolle Schritt. ISO 42001 bietet dafür das Managementsystem.

So unterstützt UniqSuite den Weg

UniqSuite ist ein bewusst einfaches Werkzeug für genau diesen Weg. Es führt in sechs Phasen von Scope bis Audit, bewertet jede Anforderung nur einmal und erzeugt die Berichte, die Leitung und Prüfer erwarten.

**Willkommen bei UniqSuite**
Drei Fragen, dann geht es los.

1 Firma

2 Paket

3 Größe

Was wollen Sie nachweisen?

NIS2
Gesetzliche Pflicht für wichtige und besonders wichtige Einrichtungen.

ISO 27001
Zertifizierbares Informationssicherheits-Managementsystem.

NIS2 + ISO 27001
Beides zusammen — gleiche Anforderungen werden nur einmal bewertet.

Zusätzlich (optional)

☒ EU AI Act

☐ ISO 42001 (KI-Managementsystem)

☐ Cyber Resilience Act (Produkte mit digitalen Elementen)

< Zurück

Weiter >

Einrichtung in drei Fragen: Firma und Branche, Paket, Größe

Startklar in drei Fragen

Firma und Branche, das gewünschte Paket – NIS2, ISO 27001 oder beides, optional AI Act, ISO 42001 und CRA – und die Zahl der Beschäftigten. Danach öffnet sich direkt die Gap-Analyse.

Fünf Kataloge, 910 bewertbare Anforderungen

NIS2	268
ISO/IEC 27001	318
EU AI Act	130
ISO/IEC 42001	111
Cyber Resilience Act	83

227 gemeinsame Kontrollpunkte verbinden 454 inhaltsgleiche Anforderungen über Regelwerksgrenzen hinweg. Eine Antwort gilt automatisch in jedem Regelwerk, das denselben Kontrollpunkt nutzt.

Eine Frage pro Karte – oder die volle Tabelle

Anforderung bewerten 148 offen

Nur offene Alle

c11.1 MUSS T01 · Geltungsbereich, Registrierung & Domänendaten

1 von 148

Ein EU-Vertreter, der die Voraussetzungen erfüllt, ist wirksam benannt (Gilt nur für Anbieter nach Art. 26(1)(b) ohne Niederlassung in der EU, die Dienste in der EU anbieten.)

✓ Umgesetzt

Teilweise

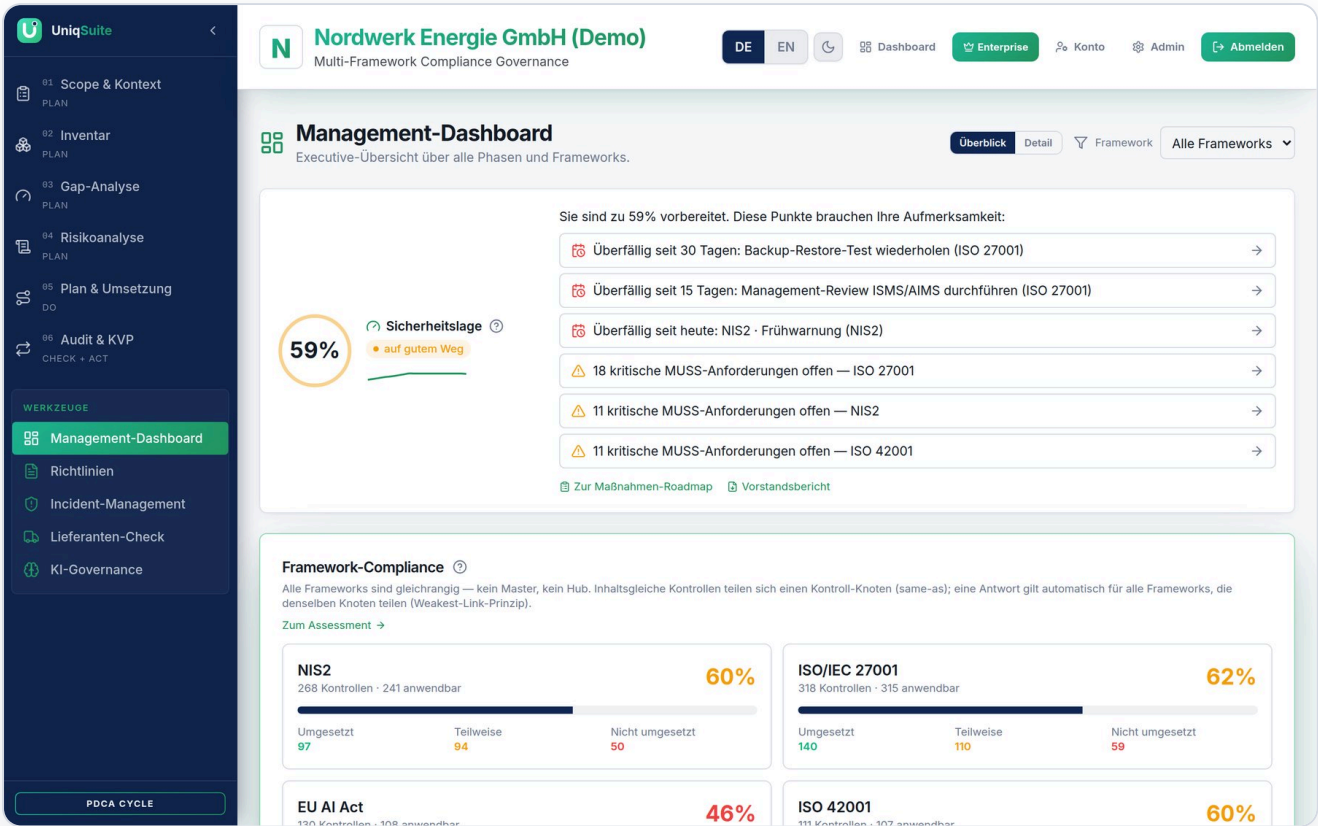
× Nicht umgesetzt

Nicht anwendbar ...

< Zurück Weiter >

Überblick: Pflichtanforderungen zuerst, Antwort mit einem Klick. „Nicht anwendbar“ verlangt eine Begründung für die SoA. Im Detail-Modus stehen Reifegrad, Nachweise und Notizen je Anforderung zur Verfügung.

Ein Stand für Leitung, Team und Prüfer



Management-Dashboard: Gesamtstand, Trend und die Punkte, die jetzt Aufmerksamkeit brauchen. Demo-Mandant.

Von der Anforderung zum Nachweis

Anforderung	Unterstützung in UniqSuite	Ergebnis / Nachweis
Betroffenheit und Scope	Phase 01 „Scope & Kontext“: Firma, Sektor, Größe, Personen, Regelwerke	Scope-Bericht
Risikoanalyse (a)	Phase 04: Risiken aus Lücken ableiten, bewerten, behandeln	Risikobericht (PDF, Word, Excel)
Vorfälle und Meldung (b)	Incident-Management: Meldepflichten je Regelwerk, Fristen-Timer, Meldestellen-Verzeichnis, MTTD/MTTR	Vorfallregister, Register-Bericht
Lieferkette (d)	Lieferanten-Check: Kritikalität, Kontrollen, Risikoscore, Review-Zyklus	Lieferantenbewertung
Richtlinien (a, g, h, i)	Richtlinien-Vorlagen mit Bezug zu den Anforderungen	Freigabefähige Richtlinien
Umsetzung und Leitung	Phase 05: SoA und eine Maßnahmenliste mit Zuständigen, Fristen, Status	SoA, Umsetzungs- und Vorstandsbericht
Wirksamkeit (f)	Phase 06 „Audit & KVP“: Befunde, Korrekturmaßnahmen, Nachverfolgung	Auditbericht

VERTRAUEN

Sicher und nachvollziehbar

- ✓ **Mandantentrennung in der Datenbank:**
Zeilenbasierte Zugriffsregeln trennen die Daten jeder Organisation.
- ✓ **Zwei-Faktor-Anmeldung,** für Administratoren verpflichtend schaltbar.
- ✓ **Tägliche Sicherungen** mit 14 Tagen Aufbewahrung.
- ✓ **Regelbasiert statt Blackbox:** Bewertungen und Kennzahlen folgen festen, nachvollziehbaren Regeln – keine KI entscheidet über Ihren Stand.
- ✓ **Aktuell:** Die Kataloge berücksichtigen bereits die geänderten Fristen des AI Act aus der Verordnung (EU) 2026/1744.

EHRlich GESAGT

Was UniqSuite nicht ersetzt

Ein Werkzeug schafft Überblick und Nachweise.
Es ersetzt nicht

- die rechtliche Prüfung Ihrer Betroffenheit im Einzelfall,
- die Entscheidung und Verantwortung der Geschäftsleitung,
- technische Sicherheitsmaßnahmen selbst,
- eine unabhängige Prüfung oder Zertifizierung.

AUSBLICK

KI und Produkte: die nächsten Pflichten

EU AI Act

Verbote und KI-Kompetenz gelten seit Februar 2025, Transparenzpflichten seit August 2026. Hochrisiko-KI folgt ab Dezember 2027. Erster Schritt: ein KI-Register.

ISO/IEC 42001

Das Managementsystem für KI. Es nutzt dieselbe Struktur wie ISO 27001 – wer ein ISMS betreibt, kann darauf aufbauen.

Cyber Resilience Act

Hersteller von Produkten mit digitalen Elementen melden seit September 2026 aktiv ausgenutzte Schwachstellen. Ab Dezember 2027 gilt der CRA vollständig.

Ihr 30-Tage-Plan

Woche 1

Betroffenheit dokumentieren, Registrierung prüfen, Verantwortliche benennen.

Woche 2

Erster Durchgang der Gap-Analyse – Pflichten Anforderungen zuerst.

Woche 3

Meldeprozess festlegen und kritische Lieferanten bewerten.

Woche 4

Maßnahmenplan von der Leitung freigeben lassen, ersten Bericht ablegen.

Sehen Sie Ihren Stand – in einer einzigen Sicht.

Drei Fragen zur Einrichtung, dann die erste Anforderung. Fordern Sie einen Zugang an oder vereinbaren Sie eine kurze Vorführung mit Ihren eigenen Fragen.

uniq.cyberwerk.online

Quellen

1. Richtlinie (EU) 2022/2555 (NIS2), insb. Art. 20, 21, 23, 34 – eur-lex.europa.eu/eli/dir/2022/2555/oj
2. Gesetz zur Umsetzung der NIS-2-Richtlinie (NIS2UmsuCG), BGBl. 2025 I Nr. 301 vom 5.12.2025 – recht.bund.de/bgbli/1/2025/301/VO.html
3. BSI: NIS-2-regulierte Unternehmen, Registrierung und Betroffenheitsprüfung – bsi.bund.de
4. Verordnung (EU) 2024/1689 (KI-Verordnung) – eur-lex.europa.eu/eli/reg/2024/1689/oj
5. Verordnung (EU) 2026/1744 zur Änderung der KI-Verordnung – eur-lex.europa.eu/eli/reg/2026/1744/oj
6. Verordnung (EU) 2024/2847 (Cyber Resilience Act) und Meldepflichten – digital-strategy.ec.europa.eu/en/policies/cra-reporting
7. ENISA: Single Reporting Platform für den CRA, September 2026 – enisa.europa.eu
8. Bitkom: Wirtschaftsschutz 2026, Präsentation, August 2026 – bitkom.org
9. Zahl der erfassten Einrichtungen in Deutschland: Berichterstattung zum Kabinettsbeschluss, u. a. cio.de und channelpartner.de
10. Durchführungsverordnung (EU) 2024/2690 – eur-lex.europa.eu/eli/reg_impl/2024/2690/oj
11. ISO/IEC 27001:2022 und ISO/IEC 42001:2023 – iso.org

Hinweis. Dieses White Paper dient der allgemeinen Information und gibt den Stand Oktober 2026 wieder. Es stellt keine Rechtsberatung dar und ersetzt nicht die Prüfung im Einzelfall. Die Zuordnung zu ISO/IEC 27001 ist eine fachliche Orientierung. Alle Unternehmensnamen und Zahlen im Beispiel sind fiktiv und stammen aus einem Demo-Mandanten. ISO und IEC sind Marken ihrer jeweiligen Inhaber.